

**FATEC – FACULDADE DE TECNOLOGIA DE SÃO CAETANO DO SUL
ANTÔNIO RUSSO**

**ISG012 — Atividades 01 e 02: Arquitetura de
Redes Seguras e Roteamento Seguro com ACLs**

Efraim de Almeida Lima

**Junho – 2026
SÃO CAETANO - SP**

ÍNDICE

1. Objetivo
2. Atividade ISG012-01 – Teoria: Arquitetura de Redes Seguras
3. Atividade ISG012-01 – Prática: Laboratório de Arquitetura Segmentada
4. Atividade ISG012-02 – Teoria: Roteamento Seguro e ACLs
5. Atividade ISG012-02 – Prática: Configuração de Roteador Linux com nftables
6. Conclusão

Objetivo

Este trabalho tem por objetivo consolidar os fundamentos de arquitetura de redes seguras, compreendendo a transição do modelo de perímetro para abordagens modernas como Zero Trust e Defense in Depth (ISG012-01), bem como a aplicação de roteamento seguro com ACLs no Linux utilizando nftables para controle de tráfego inter-VLAN (ISG012-02). A atividade integra teoria e prática laboratorial para desenvolver competência na implementação de infraestruturas de rede segmentadas e resilientes.

Atividade ISG012-01 - Teoria: Arquitetura de Redes Seguras

Questão 1

Explique a diferença fundamental entre o modelo de segurança baseado em perímetro e a arquitetura Zero Trust, destacando como cada abordagem trata o tráfego interno à rede corporativa.

Resposta:

O modelo de perímetro, predominante nas décadas de 1990 e 2000, opera sob a premissa "hard outside, soft inside": a segurança é concentrada na borda da rede (firewalls de borda), e todo tráfego que já se encontra dentro da rede goza de confiança implícita. Esse modelo pressupõe que ameaças são apenas externas — uma vez autenticado na borda, o usuário ou dispositivo pode se movimentar livremente pelo interior da rede sem reautenticação contínua. A limitação crítica é que um único comprometimento na borda (ou a partir de um dispositivo BYOD ou ameaça interna) expõe toda a rede, permitindo movimentação lateral irrestrita.

O modelo Zero Trust ("Nunca Confie, Sempre Verifique"), desenvolvido inicialmente pelo Forrester Research e formalizado pelo NIST na publicação SP 800-207, representa uma ruptura epistemológica: elimina o conceito de "rede confiável" independentemente da localização de origem do acesso. Cada solicitação de acesso — mesmo originada dentro da rede corporativa

— exige verificação explícita contínua de identidade, dispositivo e contexto. Internamente, o Zero Trust impõe microssegmentação granular entre workloads e usuários, aplica o princípio de privilégio mínimo e opera sob a assunção de brecha (assume breach), projetando controles como se o perímetro já tivesse sido violado. O tráfego interno é tratado com o mesmo nível de desconfiança que o tráfego externo.

Questão 2

Descreva o conceito de Defense in Depth e explique como a segmentação de rede contribui especificamente para este framework estratégico.

Resposta:

Defense in Depth (Defesa em Profundidade) é uma estratégia de segurança inspirada em táticas militares que emprega múltiplas camadas de controles defensivos ao longo do caminho de dados. O princípio central é que nenhum controle é infalível; portanto, a redundância estratégica e a diversidade defensiva garantem que a falha de um único mecanismo não resulte em comprometimento total do ambiente. As camadas típicas são: Políticas → Perímetro → Rede → Endpoint → Aplicação → Dados. Cada camada integra controles de prevenção (firewalls), detecção (IDS/IPS) e resposta (contenção), retardando a progressão do atacante e reduzindo o impacto de brechas isoladas.

A segmentação de rede contribui diretamente para o Defense in Depth ao atuar como camada de isolamento lógico dentro da infraestrutura. Ao dividir a rede em zonas com políticas de tráfego específicas (ex.: Management, Internal, DMZ, External), a segmentação contém o raio de explosão (blast radius) de incidentes: mesmo que um segmento seja comprometido, o atacante enfrenta barreiras adicionais (firewalls inter-VLAN, ACLs) para alcançar segmentos críticos. Isso retarda a movimentação lateral, facilita a detecção de anomalias inter-segmentos e limita a superfície de ataque disponível ao adversário em cada estágio do Kill Chain.

Questão 3

Análise a função estratégica da DMZ (Demilitarized Zone) em uma

arquitetura de rede segura, explicando por que serviços expostos à Internet não devem residir diretamente na rede interna corporativa.

Resposta:

A DMZ é uma sub-rede intermediária posicionada entre a Internet (zona não confiável) e a rede interna corporativa (zona confiável). Sua função estratégica é hospedar serviços que precisam ser acessíveis externamente — servidores web, DNS, e-mail, FTP — em um ambiente isolado, de forma que o comprometimento de um servidor na DMZ não implique acesso direto aos ativos internos sensíveis.

A razão pela qual serviços públicos não devem residir na rede interna é que qualquer vulnerabilidade explorada nesses serviços forneceria ao atacante um foothold imediato dentro da rede corporativa, com acesso direto a sistemas de ERP, bancos de dados, servidores de arquivos e outros ativos críticos. Com a DMZ, aplica-se o princípio "comprometimento da DMZ ≠ acesso à rede interna": entre a DMZ e a rede interna existe um segundo firewall (firewall interno), mais restritivo, que bloqueia conexões iniciadas a partir da DMZ. A arquitetura típica utiliza duplo firewall (ou tri-homed firewall): o firewall externo filtra tráfego entre Internet e DMZ, permitindo apenas portas específicas (80, 443, 25, 53); o firewall interno protege a rede interna da DMZ, aceitando apenas respostas a conexões iniciadas internamente. Dessa forma, a DMZ atua como zona de contenção que aumenta significativamente o custo e a complexidade de um ataque completo.

Questão 4

Discorra sobre como o subnetting pode ser utilizado como ferramenta de segurança, indo além de sua função tradicional de otimização de endereçamento IP.

Resposta:

Tradicionalmente, o subnetting serve para otimizar o uso do espaço de endereçamento IP e reduzir domínios de broadcast. Porém, do ponto de vista da segurança, o subnetting constitui uma ferramenta de microssegmentação que isola grupos de dispositivos em domínios lógicos distintos, controlados por políticas de tráfego específicas.

Ao criar sub-redes separadas por função (ex.: 192.168.1.0/24 para usuários internos, 192.168.2.0/24 para a DMZ, 192.168.3.0/24 para gerenciamento), o administrador cria fronteiras naturais onde roteadores ou firewalls podem aplicar ACLs granulares para controlar quais segmentos se comunicam e em quais condições. Isso elimina a comunicação lateral irrestrita entre dispositivos — um host comprometido em uma sub-rede não pode alcançar diretamente hosts em outra sub-rede sem passar pelo ponto de controle (firewall/roteador). Adicionalmente, o subnetting facilita a aplicação de políticas de QoS por segmento, a implementação de honeypots em sub-redes dedicadas para detecção de movimentação lateral, e a auditoria de tráfego inter-sub-rede por meio de logs no gateway. Em síntese, o subnetting transforma a topologia de rede em um instrumento ativo de contenção de incidentes.

Questão 5

Explique a importância da zona de Management separada fisicamente ou logicamente da rede de produção, citando controles específicos recomendados para este segmento crítico.

Resposta:

A zona de Management (gerenciamento) é um segmento dedicado exclusivamente ao acesso administrativo à infraestrutura (roteadores, switches, firewalls, servidores). Sua separação da rede de produção é estrategicamente crítica porque, se comprometida, a rede de gerenciamento concederia ao atacante controle total sobre todos os dispositivos gerenciados — um cenário catastrófico que tornaria ineficazes todos os demais controles de segurança.

Controles específicos recomendados para este segmento incluem: (1) **Acesso via Jump Host / Bastion Host:** todo acesso administrativo deve ser roteado obrigatoriamente por um servidor intermediário com autenticação multifator (MFA), que registra todas as sessões; (2) **ACLs restritivas:** apenas endereços IP explicitamente autorizados podem iniciar conexões à zona de Management; nenhuma conexão originada da Management deve ser permitida ao tráfego de produção sem justificativa; (3) **Protocolos seguros exclusivos:** SSH (porta 22) e HTTPS (443) para gerenciamento, banindo Telnet e HTTP; (4) **VLAN dedicada com trunk criptografado:**

isolamento lógico via VLAN com 802.1Q, garantindo que tráfego de gerenciamento não vaze para outras VLANs; (5) **Logging e alertas em tempo real**: todo acesso à zona deve gerar logs auditáveis, integrados a um SIEM para detecção de acessos não autorizados.

Questão 6

Compare as abordagens de segmentação VLAN (camada 2) e microssegmentação baseada em identidade (camada 7), discutindo cenários onde cada uma é mais apropriada.

Resposta:

A segmentação por VLAN opera na camada 2 do modelo OSI (enlace de dados), dividindo domínios de broadcast logicamente em um mesmo switch físico sem necessidade de roteadores separados. A separação é baseada em critérios como porta do switch, endereço MAC ou tag 802.1Q. É uma solução madura, de baixo custo e amplamente suportada. É mais apropriada em ambientes on-premise tradicionais com infraestrutura física definida, onde grupos de usuários ou dispositivos têm fronteiras claras e estáveis (ex.: VLAN de VoIP, VLAN de usuários corporativos, VLAN de servidores). A limitação principal é que a segmentação VLAN não é granular o suficiente para controlar comunicação entre workloads dentro do mesmo segmento, e a identidade do usuário não é considerada — apenas a localização de rede.

A microssegmentação baseada em identidade opera na camada 7 (aplicação), associando políticas de acesso à identidade do usuário, do dispositivo ou da carga de trabalho (workload), independentemente da localização de rede. É a abordagem característica do Zero Trust: um usuário autenticado recebe acesso apenas às aplicações e dados para os quais tem autorização explícita, mesmo que esteja na mesma sub-rede que outros usuários. É mais apropriada em ambientes de nuvem híbrida, data centers com alta densidade de workloads virtualizados/containerizados, e cenários de trabalho remoto onde a localização física é irrelevante. A desvantagem é a maior complexidade de implementação e a necessidade de soluções específicas (ex.: SDN, plataformas de identidade como Okta, Zscaler, AWS IAM).

Atividade ISG012-01 – Prática: Laboratório de Arquitetura Segmentada

Questão Prática 1

Qual comando Linux você utilizaria para verificar se a interface de rede da VM Linux Mint (gateway) está corretamente configurada em modo promíscuo para escutar tráfego entre segmentos, e como você validaria que o roteamento estático entre VLANs está funcional?

Resposta:

Para verificar o modo promíscuo de uma interface de rede no Linux, utiliza-se o comando:

```
ip link show eth0
```

Na saída, a flag `PROMISC` indica que a interface está em modo promíscuo. Alternativamente:

```
cat /sys/class/net/eth0/flags
```

O valor `0x103` (em vez de `0x1003`) indica modo promíscuo ativo. Para ativar o modo promíscuo manualmente:

```
ip link set eth0 promisc on
```

Para validar que o roteamento estático entre VLANs está funcional, os passos são:

Verificar IP forwarding está ativo:

```
sysctl net.ipv4.ip_forward  
# Deve retornar: net.ipv4.ip_forward = 1
```

Verificar a tabela de roteamento:

```
ip route show
```

Testar conectividade entre segmentos com ping:

```
# A partir da rede Internal (192.168.1.x), pingar host na DMZ  
ping -c 4 192.168.2.1
```


Rastrear o caminho dos pacotes:

```
traceroute 192.168.2.1
```

Questão Prática 2

Durante a configuração do Linux Mint como gateway entre zonas, implemente uma regra nftables que bloqueie todo tráfego originado na DMZ (192.168.2.0/24) com destino à rede Management (192.168.3.0/24), mantendo o acesso permitido da Internal para DMZ.

Resposta:

```
# Criar a tabela e chains necessárias
nft add table inet firewall
nft add chain inet firewall forward { type filter hook forward priority 0 \;
policy drop \; }

# Permitir tráfego estabelecido/relacionado (stateful)
nft add rule inet firewall forward ct state established,related accept

# Permitir tráfego da rede Internal (192.168.1.0/24) para a DMZ
(192.168.2.0/24)
nft add rule inet firewall forward ip saddr 192.168.1.0/24 ip daddr
192.168.2.0/24 accept

# BLOQUEAR tráfego da DMZ (192.168.2.0/24) para Management (192.168.3.0/24)
nft add rule inet firewall forward ip saddr 192.168.2.0/24 ip daddr
192.168.3.0/24 drop

# Verificar as regras aplicadas
nft list ruleset
```

A política padrão `drop` na chain `forward` garante que somente tráfego explicitamente permitido atravesse o gateway. A regra de `established,related` permite que respostas a conexões iniciadas internamente retornem normalmente sem criar regras individuais de retorno.

Questão Prática 3

Após configurar os endereços IP em cada interface (eth0-External, eth1-Internal, eth2-DMZ, eth3-Management), qual comando você

utilizaria para habilitar o IP forwarding no kernel Linux e como você configuraria uma rota estática específica para que a rede Internal (192.168.1.0/24) alcance a rede External (10.0.0.0/24) através do gateway 192.168.1.1?

Resposta:

Habilitar IP Forwarding (temporário):

```
sysctl -w net.ipv4.ip_forward=1
```

Habilitar IP Forwarding (persistente entre reinicializações):

```
echo "net.ipv4.ip_forward=1" >> /etc/sysctl.conf  
sysctl -p
```

Configurar rota estática (temporária):

```
ip route add 10.0.0.0/24 via 192.168.1.1 dev eth1
```

Configurar rota estática (persistente via netplan no Linux Mint/Ubuntu):

```
# /etc/netplan/01-network.yaml  
network:  
  version: 2  
  ethernets:  
    eth1:  
      addresses: [192.168.1.1/24]  
      routes:  
        - to: 10.0.0.0/24  
          via: 192.168.1.1
```

```
netplan apply
```

Verificar a rota inserida:

```
ip route show  
# ou  
ip route get 10.0.0.1
```

Atividade ISG012-02 – Teoria: Roteamento Seguro e ACLs

Pergunta 1

Explique a diferença fundamental entre roteamento estático e roteamento dinâmico sob a ótica da segurança de redes.

Resposta:

O roteamento estático consiste na inserção manual de rotas na tabela de roteamento pelo administrador, sem troca automática de informações entre roteadores. Do ponto de vista da segurança, oferece previsibilidade total: o administrador sabe exatamente por onde o tráfego flui em todo momento, eliminando surpresas causadas por alterações automáticas de topologia. Não há superfície de ataque relacionada à injeção de rotas falsas por dispositivos maliciosos, e a ausência de protocolos de roteamento rodando reduz o número de serviços expostos. A desvantagem é a necessidade de manutenção manual em caso de falhas de links, tornando-o inadequado para redes grandes ou dinâmicas.

O roteamento dinâmico utiliza protocolos (RIP, OSPF, BGP) para que roteadores troquem informações de topologia automaticamente, adaptando-se a mudanças. O risco principal de segurança reside na possibilidade de um roteador malicioso ou comprometido injetar rotas falsas na rede (route injection / route poisoning), desviando o tráfego para interceptação — um ataque Man-in-the-Middle em nível de rede. Por isso, em ambientes seguros, o roteamento dinâmico deve ser combinado com autenticação de vizinhos (MD5/SHA para OSPF, MD5 para RIPv2), filtragem de prefixos e isolamento em áreas. A escolha entre estático e dinâmico deve considerar o trade-off entre previsibilidade/segurança e escalabilidade/resiliência.

Pergunta 2

Descreva o funcionamento do RIP como protocolo distance-vector e explique por que a versão 1 é considerada insegura em comparação com a versão 2.

Resposta:

O RIP (Routing Information Protocol) é um protocolo de roteamento distance-vector onde cada roteador mantém apenas o conhecimento da distância (contagem de saltos/hops) e da direção (next-hop) para cada destino. A cada 30 segundos, cada roteador compartilha sua tabela de roteamento completa com seus vizinhos diretos. A métrica é a contagem de saltos, com limite máximo de 15 (redes com 16 hops são consideradas

inalcançáveis), tornando-o inadequado para redes grandes. Mecanismos como split horizon e poison reverse previnem loops de roteamento.

O RIPv1 é considerado inseguro por três razões principais: (1) **Ausência total de autenticação** — qualquer dispositivo na rede pode enviar atualizações de roteamento falsas e ter suas rotas aceitas, possibilitando ataques de injeção de rotas para desvio de tráfego; (2) **Uso de broadcast** (255.255.255.255) — as atualizações são enviadas para toda a rede, expondo informações de topologia para qualquer host no segmento; (3) **Classful routing** — não suporta VLSM (Variable Length Subnet Masking), limitando a flexibilidade de endereçamento.

O RIPv2 resolveu estas vulnerabilidades introduzindo: suporte a autenticação (senha em texto simples ou hash MD5), uso de multicast direcionado (224.0.0.9) reduzindo a exposição, e suporte a VLSM/CIDR. Apesar das melhorias, a autenticação MD5 do RIPv2 ainda não garante confidencialidade das atualizações — apenas autenticidade — e o protocolo permanece inadequado para ambientes corporativos de grande escala.

Pergunta 3

Explique o conceito de áreas no OSPF e como essa hierarquia contribui para a segurança da rede.

Resposta:

O OSPF (Open Shortest Path First) é um protocolo link-state que divide a rede em áreas hierárquicas para melhorar escalabilidade e controle. A estrutura central é a Área 0 (backbone), à qual todas as demais áreas devem se conectar diretamente ou via virtual-links. Roteadores que conectam áreas não-backbone à Área 0 são denominados ABR (Area Border Router).

Cada área mantém seu próprio banco de dados de estado de links (LSDB — Link State Database), e o cálculo de rotas pelo algoritmo SPF de Dijkstra é feito independentemente dentro de cada área. Isso significa que um roteador numa área específica não possui visibilidade completa da topologia de outra área — conhece apenas os prefixos resumidos (summary LSAs) divulgados pelos ABRs.

Do ponto de vista da segurança, essa hierarquia contribui de três formas: (1) **Contenção de falhas e ataques**: uma injeção de LSA falso em uma área fica contida naquela área, não se propagando para toda a rede; (2) **Redução de exposição de topologia**: hosts e dispositivos em uma área não têm visibilidade da topologia interna de outras áreas, dificultando o mapeamento da rede por um atacante; (3) **Áreas stub e totally stubby**: configurando áreas como stub, o ABR impede a propagação de LSAs tipo 5 (rotas externas), reduzindo o tamanho da LSDB e a superfície de ataque a injeções de rotas externas. Complementarmente, a autenticação OSPF por área (simples, MD5 ou HMAC-SHA) garante que apenas roteadores autorizados participem das trocas de topologia.

Pergunta 4

O que é Policy-Based Routing (PBR) e como ele pode ser utilizado para implementar path isolation em um roteador Linux multi-homed?

Resposta:

Policy-Based Routing (PBR) é uma técnica de roteamento que permite tomar decisões de encaminhamento de pacotes baseadas em critérios além do destino IP — como endereço de origem, protocolo, porta, interface de entrada ou marca de pacote (packet mark). No Linux, o PBR é implementado através de múltiplas tabelas de roteamento e regras de política gerenciadas pelos comandos `ip rule` e `ip route`.

Para implementar path isolation em um roteador Linux multi-homed (com múltiplas interfaces), o administrador cria tabelas de roteamento separadas para cada segmento:

```
# Criar tabelas de roteamento nomeadas em /etc/iproute2/rt_tables
echo "100 management" >> /etc/iproute2/rt_tables
echo "200 internal" >> /etc/iproute2/rt_tables

# Adicionar regras: tráfego oriundo do segmento Management usa tabela
dedicada
ip rule add from 192.168.3.0/24 table management priority 100
ip route add default via 192.168.3.254 table management

# Tráfego oriundo do Internal usa outra tabela
ip rule add from 192.168.1.0/24 table internal priority 200
ip route add default via 192.168.1.254 table internal
```

O path isolation garante que tráfego de um segmento nunca seja inadvertidamente roteado por um caminho destinado a outro segmento, prevenindo vazamentos de tráfego entre zonas de diferentes níveis de confiança. É especialmente útil em cenários onde diferentes segmentos devem usar links de ISP distintos ou onde o tráfego de gerenciamento não deve jamais utilizar o mesmo caminho que o tráfego de produção.

Pergunta 5

Explique a importância do hook forward no nftables para a segurança de um roteador Linux e diferencie-o dos hooks input e output.

Resposta:

No framework Netfilter/nftables, os hooks são pontos de interceptação no stack de rede do kernel Linux onde as regras de firewall são avaliadas. Os três hooks principais para filtragem são:

Input: Processa pacotes destinados ao próprio roteador Linux (endereço IP de uma de suas interfaces). Usado para proteger o próprio sistema, por exemplo, controlar acesso SSH à máquina.

Output: Processa pacotes gerados pelo próprio roteador Linux e destinados a outros hosts. Controla o tráfego originado na máquina roteadora.

Forward: Processa pacotes que **transitam** pelo roteador — originados em um host de uma sub-rede e destinados a um host em outra sub-rede. O roteador não é origem nem destino final, apenas intermediário.

Para um roteador Linux multi-homed, o hook **forward** é o mais crítico para a segurança da rede, pois todo o tráfego inter-segmentos passa por ele. As ACLs implementadas no forward determinam quais redes podem se comunicar entre si, bloqueando movimentação lateral indesejada. Por exemplo:

```
# Chain forward com política padrão drop — nada passa sem permissão explícita
nft add chain inet firewall forward { type filter hook forward priority 0 \;
policy drop \; }

# Permitir apenas Internal → DMZ; bloquear DMZ → Internal
nft add rule inet firewall forward iifname "eth1" oifname "eth2" ip saddr
192.168.1.0/24 accept
```

Sem regras no hook forward, mesmo com `ip_forward=1` ativo, o roteador encaminharia todo tráfego sem restrições — um risco crítico de segurança.

Pergunta 6

Descreva o princípio do "menor privilégio" aplicado à configuração de ACLs em roteadores e explique por que a política padrão drop é considerada uma boa prática de segurança.

Resposta:

O princípio do menor privilégio (Principle of Least Privilege — PoLP) determina que cada entidade — usuário, processo, dispositivo ou segmento de rede — deve ter acesso apenas ao mínimo necessário para exercer sua função legítima, e nada além disso. Aplicado à configuração de ACLs em roteadores, significa que ao invés de definir regras que bloqueiem tráfego indesejado (modelo blacklist/deny-specific), o correto é definir explicitamente apenas o tráfego que deve ser permitido e descartar todo o restante (modelo whitelist/allow-specific).

A política padrão `drop` (default deny) implementa exatamente esse princípio: a chain de firewall é configurada para descartar silenciosamente qualquer pacote que não corresponda a uma regra de permissão explícita. As razões pelas quais essa é uma boa prática de segurança são:

Proteção contra tráfego desconhecido: Novos protocolos, portas ou vetores de ataque não contemplados nas regras são automaticamente bloqueados sem necessidade de atualização da política;

Fail-safe: Em caso de falha ou exclusão acidental de uma regra permissiva, o sistema falha de forma segura (tráfego bloqueado) em vez de insegura (tráfego liberado);

Auditabilidade: Com `policy drop`, qualquer tráfego que está fluindo corresponde necessariamente a uma regra explícita documentada, facilitando auditorias de conformidade;

Redução de superfície de ataque: Apenas os caminhos de comunicação estritamente necessários existem, minimizando as oportunidades de exploração.

A alternativa — política padrão `accept` com regras de bloqueio específicas — é inerentemente insegura porque qualquer tráfego não contemplado

nas regras de bloqueio passa livremente.

Atividade ISG012-02 – Prática: Configuração de Roteador Linux com nftables

Pergunta Prática 1

Qual comando habilita o encaminhamento de pacotes (IP forwarding) no kernel Linux e como tornar essa configuração persistente entre reinicializações?

Resposta:

Ativação temporária (vigente até próximo reboot):

```
sysctl -w net.ipv4.ip_forward=1
# ou equivalente:
echo 1 > /proc/sys/net/ipv4/ip_forward
```

Ativação persistente (sobrevive a reinicializações):

```
# Editar o arquivo de configuração do sysctl
echo "net.ipv4.ip_forward=1" >> /etc/sysctl.conf

# Aplicar imediatamente sem reiniciar
sysctl -p

# Para IPv6 também (se necessário)
echo "net.ipv6.conf.all.forwarding=1" >> /etc/sysctl.conf
```

Verificação:

```
sysctl net.ipv4.ip_forward
# Saída esperada: net.ipv4.ip_forward = 1
```

Sem o IP forwarding ativo, o kernel Linux descarta silenciosamente pacotes que chegam em uma interface e são destinados a outra rede (comportamento padrão de host, não de roteador). Com o forwarding ativo, o kernel encaminha esses pacotes para a interface de saída correta conforme a tabela de roteamento, e as chains `forward` do nftables são invocadas para aplicar as políticas de segurança.

Pergunta Prática 2

Qual regra do nftables implementa o bloqueio completo de tráfego entre o segmento de visitantes (eth3) e o segmento de servidores (eth2), incluindo logging para auditoria?

Resposta:

```
# Criar tabela e chain forward com política padrão drop
nft add table inet acl_router
nft add chain inet acl_router forward { type filter hook forward priority
0 \; policy drop \; }

# Permitir tráfego estabelecido/relacionado (respostas a conexões
existentes)
nft add rule inet acl_router forward ct state established,related accept

# Log de tentativas de acesso de visitantes (eth3) para servidores (eth2)
nft add rule inet acl_router forward iifname "eth3" oifname "eth2" log
prefix "BLOCK-VISITORS-TO-SERVERS: " drop

# Log de tentativas inversas (servidores tentando alcançar visitantes)
nft add rule inet acl_router forward iifname "eth2" oifname "eth3" log
prefix "BLOCK-SERVERS-TO-VISITORS: " drop

# Verificar regras
nft list table inet acl_router
```

Os logs serão registrados no syslog do sistema (tipicamente /var/log/syslog ou via journalctl -k). O prefixo facilita a filtragem em ferramentas de análise de logs:

```
# Monitorar tentativas em tempo real
journalctl -k -f | grep "BLOCK-VISITORS"
```

Pergunta Prática 3

Como verificar se as regras do nftables foram carregadas corretamente e qual comando lista a tabela de roteamento principal no Linux?

Resposta:

Verificação das regras nftables:

```
# Listar todas as tabelas, chains e regras
nft list ruleset
```

```
# Listar apenas uma tabela específica
nft list table inet acl_router

# Listar apenas uma chain específica
nft list chain inet acl_router forward

# Verificar contadores de pacotes/bytes por regra
nft list ruleset -a

# Monitorar eventos nftables em tempo real
nft monitor
```

Listagem da tabela de roteamento principal:

```
# Método moderno (iproute2)
ip route show
# ou
ip route list table main

# Ver tabela completa incluindo rotas de cache
ip route show cache

# Verificar rota específica para um destino
ip route get 192.168.2.1

# Método legado (ainda disponível)
route -n
netstat -rn
```

Verificação combinada para diagnóstico completo:

```
# Interface e endereços
ip addr show
# Rotas
ip route show
# Regras de PBR
ip rule show
# Regras de firewall
nft list ruleset
# IP forwarding
sysctl net.ipv4.ip_forward
```

Conclusão

Esta atividade consolidou dois pilares fundamentais da segurança em redes: a arquitetura de segmentação lógica (ISG012-01) e o controle de tráfego via roteamento seguro com ACLs (ISG012-02).

A análise comparativa entre o modelo de perímetro e o Zero Trust evidencia a necessidade de evolução das estratégias de defesa, migrando

de uma confiança baseada em localização para uma verificação contínua e explícita de identidade e contexto. A DMZ, o subnetting e a zona de Management separada são ferramentas concretas de Defense in Depth que limitam o raio de explosão de incidentes.

Na dimensão prática, a configuração do Linux como roteador multi-homed com nftables demonstra que ferramentas open-source são plenamente capazes de implementar ACLs de nível empresarial. A política padrão `drop` com permissões explícitas, o IP forwarding controlado e o logging de tentativas bloqueadas formam a base de uma infraestrutura de roteamento seguro, auditável e alinhada ao princípio do menor privilégio.